

LIBRO BLANCO TÉCNICO PÚBLICO

ODRE PQC v0.2.9

Application-Embedded Post-Quantum Security Boundary

Evolución de seguridad · Verificación de amenazas · Evidencia multiplataforma

EDICIÓN EN ESPAÑOL

Septiembre de 2026

Contenido

01 Evolución de desarrollo y seguridad
De v0.1.1 a v0.2.9

02 Modelo de amenazas y verificación
Replay, Sequence y Native Identity

03 Verificación por plataforma
Windows Server 2022 y Ubuntu 24.04 LTS

04 Artefactos y evidencia
Wheel sellado, runtime e informes

05 Conclusión
Linaje observado y artefacto final

La descripción del producto y la arquitectura se mantienen por separado. Este documento se centra en la evolución de seguridad y la evidencia ejecutable.

Este documento no aborda la descripción general ni la arquitectura del producto. Esos temas se tratan por separado en [ODRE PQC v0.2.9 Descripción del Producto y Arquitectura de Seguridad](#). Este libro blanco registra la evolución de desarrollo y seguridad de ODRE PQC, la verificación por modelo de amenazas, los resultados de ejecución por plataforma y la trazabilidad entre los artefactos sellados y sus evidencias.

1. Evolución de Desarrollo y Seguridad

1.1 v0.1.1: Bloqueo del Bypass en Texto Plano de Rutas Protegidas

El informe v0.1.1 documenta la corrección de un bypass en texto plano de rutas protegidas, clasificado como [PQC-001 HIGH](#) en la auditoría anterior. Si una ruta protegida puede alcanzar el Consumer Handler después de fallar el runtime de seguridad, la aplicación podría ejecutarse aunque haya fallado el límite criptográfico.

v0.1.1 fijó `/secure/*` como Fail-Closed y bloqueó el bypass del Handler tras un fallo de seguridad. La verificación del Wheel v0.1.1 registró:

- SHA-256 del Wheel: [627AF68632D5C99481849CB1C43497381267CCE426F3A5DA9752B069C36D37E6](#)
- Integridad RECORD: 20/20
- Import Safety verificado
- API Plugin `install(app)` verificada
- Política de rutas protegidas: Fail-Closed
- Ejecuciones del Consumer Handler tras fallo de seguridad: 0
- Aislamiento entre rutas públicas y protegidas verificado
- Resource Lifecycle y Cleanup verificados

Esta corrección se convirtió en el contrato básico de seguridad de las versiones posteriores. La verificación se amplió a Replay, Request Binding, Native Runtime Trust, Crash Recovery y ataques específicos de plataforma.

1.2 v0.1.2: Tres Defectos Revelados por Pruebas Clean-room Después de la Verificación Funcional

Para v0.1.2 se conservan dos informes con objetivos distintos. El informe de verificación del producto examinó la API de instalación, rutas Fail-Closed, rotación, migración transaccional de la base de seguridad, Drain al finalizar, comandos de diagnóstico y recorridos del cliente. Registró 38/38 pruebas generales, 37/37 escenarios de configuración y uso incorrecto de rotación, y diez ciclos de inicio y apagado. El SHA-256 del Wheel fue [59A562C789B28C05B309AAD0BC51511D9BD16D84A783021F1598A8AF21B4F06D](#).

Una reverificación Clean-room independiente instaló el mismo Wheel en un entorno Python 3.12 nuevo con dependencias bloqueadas por hash y superó solo 17 de 20 pruebas de ataque. La instalación, el recorrido real de PQC, el recorrido del cliente, RECORD 30/30 y el ciclo de recursos pasaron, pero se reprodujeron tres defectos. El éxito funcional y de regresión no podía extenderse a toda la superficie de ataque.

1.2.1 F-001: Aceptación de Sequence Gap

La prueba retuvo Sequence 5 y envió Sequence 6. Se esperaba rechazar la solicitud con salto sin ejecutar el Handler protegido. Sequence 6 fue aceptada con HTTP 200 y el recuento del Handler aumentó de 3 a 4.

El problema era la continuidad, no solo la duplicación. Si se rechazan duplicados pero se acepta cualquier valor mayor al actual, un atacante puede omitir una solicitud intermedia o alterar el orden y aun así avanzar la sesión. La verificación debe confirmar atómicamente que el valor es exactamente el siguiente, no solo que no fue usado.

1.2.2 F-002: Handler Ejecutado Antes de Decidir Sobre una Respuesta Sobredimensionada

Cuando el Handler protegido generó una respuesta superior al límite, la respuesta externa se cerró con HTTP 503 y no se observó fuga de texto plano. Sin embargo, el Handler se ejecutó una vez antes de decidir el tamaño.

La respuesta de red final no es el único riesgo. Un Handler puede modificar una base de datos, invocar servicios externos o escribir archivos. Rechazar la salida después de ejecutarlo puede dejar efectos secundarios. Los contratos de respuesta no admitidos deben identificarse antes de entrar al Handler.

1.2.3 F-003: Handler Ejecutado Antes de Decidir Sobre Streaming no Admitido

Streaming, SSE, Iterator y WebSocket no estaban admitidos por el contrato de respuesta protegida. La respuesta externa se cerró con HTTP 503 sin fuga de texto plano, pero el Handler se ejecutó una vez antes de evaluar el tipo. Como en F-002, la decisión Fail-Closed se produjo demasiado tarde.

El informe Clean-room de v0.1.2 conservó los hallazgos sin modificar el producto durante la auditoría. La corrección y el cierre se asignaron a v0.1.3.

1.3 v0.1.3: Strict Sequence y Pre-handler Contract Enforcement

v0.1.3 cerró los tres hallazgos cambiando el orden de aplicación en el límite de seguridad.

- Se rechazaron Sequence Gap, Rollback y Duplicate.
- Los contratos de respuesta sobredimensionada o sin límite previo se rechazaron antes del Handler.
- Streaming, SSE, Iterator y WebSocket no admitidos se rechazaron antes del Handler.

La reverificación Clean-room instaló el Wheel con `--require-hashes` en un Python 3.12 nuevo y ejecutó la copia de [site-packages](#). El recorrido normal utilizó operaciones reales OpenSSL 3.5.8 ML-KEM-768 y ML-DSA-65, no criptografía simulada.

Área de verificación	Resultado observado
Pruebas de ataque	20/20
Ejecuciones del Handler tras fallo de seguridad	0
Pruebas de configuración incorrecta	6/6
Wheel RECORD	31/31
Nuevos Critical / High / Medium	0/0/0

Las solicitudes Gap, Rollback y Duplicate fueron rechazadas con cero ejecuciones del Handler protegido. Las respuestas Oversized, Unbounded y Streaming no admitido se rechazaron antes del Handler, sin fuga de texto plano. El SHA-256 auditado fue [EAA164895F835478441465112AAEEF8F6768740FFE2908BBE7CD53298D934D12](#).

1.4 v0.1.4: Observabilidad sin Regresión del Contrato de Seguridad

v0.1.4 añadió observabilidad de estado y comprobó que el límite de protección no se debilitara. La función de estado superó 15 pruebas de producto y cuatro comprobaciones independientes con runtime real. La suite de seguridad v0.1.3 sin cambios pasó 41/41; el resultado combinado fue 56/56.

La reverificación Clean-room cubrió:

- Entorno Python 3.12 nuevo con dependencias bloqueadas por hash
- Ejecución desde el Wheel instalado
- Runtime OpenSSL real
- Recorrido real ML-KEM-768 y ML-DSA-65
- Pruebas de ataque: 20/20
- Configuración incorrecta: 6/6
- Bypass del Handler: 0
- RECORD: 32/32
- Mutaciones causadas por consultas de estado: 0
- Fugas de secretos en estado: 0
- Classical Downgrade automático: 0
- Nuevos Critical / High / Medium: 0/0/0

El SHA-256 fue [19EF222083C15D89E63B49A08D62EFEF480F3B82443839C900B6DAE425B13E54](#). v0.1.4 no comprobó solo la nueva función; volvió a confirmar las condiciones Sequence y Pre-handler que habían fallado en v0.1.2.

1.5 Linaje de Mejora v0.1.2-v0.1.4

Versión	Hallazgo o cambio	Riesgo	Corrección estructural	Reverificación
v0.1.2	Sequence Gap aceptado	Avance de sesión tras alterar el orden	Necesidad de Strict next-sequence	Clean-room 17/20; fallo conservado
v0.1.2	Handler antes de decidir Oversized	Efectos antes del rechazo externo	Evaluación Pre-handler del contrato	v0.1.3 Handler: 0
v0.1.2	Handler antes de decidir Streaming	Efectos de un tipo no admitido	Rechazo Pre-handler de tipos no admitidos	v0.1.3 Handler: 0
v0.1.3	Tres hallazgos corregidos	La corrección puede romper flujo o Packaging	Strict Sequence y Pre-handler Enforcement	Ataque 20/20; configuración 6/6; RECORD 31/31
v0.1.4	Estado añadido	La consulta cambia estado o filtra secretos	Contrato de estado Read-only y sin secretos	Estado 15+4; seguridad previa 41/41; RECORD 32/32

1.6 v0.2.4 a v0.2.5: Defecto de ABI Nativa en Ubuntu

Al probar en Ubuntu real la v0.2.4, que había pasado Windows, se descubrió que el Linux Shim omitía el export [odre_shutdown](#). El caso mostró que una ABI de Native Runtime debe verificarse por plataforma aunque la superficie Python sea idéntica.

v0.2.5 corrigió y verificó:

- Exports esperados en Ubuntu Shim: 15; reales: 15
- Export `odre_shutdown` presente
- Double Shutdown y ciclo Startup-Shutdown-Startup
- Cinco de cinco ciclos repetidos
- File Descriptor Delta: 0
- Shim descargado tras Shutdown
- Identidad de OpenSSL 3.5.8
- Ejecución real ML-KEM-768 y ML-DSA-65

Una auditoría dirigida posterior encontró un High y dos Medium adicionales, por lo que se mantuvo Release Blocking. Sus causas y correcciones pertenecen al linaje v0.2.6.

1.7 v0.2.6: Refuerzo de Native Trust, TOCTOU e Identidad FD

La evidencia v0.2.6 se divide en Blind Static Audit, Targeted Reproduction, Confirmed Root Cause, Static-to-Dynamic Classification, Remediation y Final Multi-review Audit. Las sospechas estáticas no se declararon automáticamente defectos: se probaron con Harness y se clasificaron por reproducibilidad.

Áreas principales de refuerzo:

- Cierre de TOCTOU entre el objeto verificado por hash y el objeto cargado
- Vinculación de confianza a FD e Inode reales, no a una ruta textual
- Validación de Native Provider y rutas de búsqueda de dependencias
- Prueba de identidad entre Verified Object y Loaded Object durante reemplazo, reutilización y cambio de ruta
- Repetición de regresiones en ambas plataformas

El SHA-256 oficial del Wheel v0.2.6 fue [4756FC9B219DAB4E2BF9C90FA066CFFD0D5DEA94FEF03DCE0B18DED55E5A7C7A](#).

1.8 v0.2.8 a v0.2.9: F-028-01 y Defensa Frente al Reemplazo del Objeto Padre

[F-028-01](#) se identificó en v0.2.8. La ruta de inicialización vulnerable podía permitir que un Root Symlink transitorio influyera en el resultado de `Path.resolve()` previo a la promoción.

En Linux, v0.2.9 abre y retiene la cadena de directorios padre confiables con `O_DIRECTORY | O_NOFOLLOW`, bloquea la identidad del directorio Staging y lo promueve con `renameat2(..., RENAME_NOREPLACE)` relativo al Parent-dirfd. Después verifica que `(st_dev, st_ino)` del directorio promovido coincida con el objeto Staging. La inicialización falla de forma cerrada si faltan las primitivas o la prueba de identidad.

Resultados del ataque dirigido:

- Trials: 600
- Symlink Swaps: 1,212,203
- Distribución de salida: 278 éxitos / 322 abortos seguros

- Object-Path Misbinding: 0
- Persistencia en ruta externa: 0
- Mutaciones de archivo externo: 0
- Secret Leakage: 0
- Estado parcialmente promovido: 0

La auditoría completa posterior ejecutó otro Late-promotion Parent-object Attack de 600 intentos. La inicialización falló de forma cerrada en los 600 estados de ataque, con cero Object-Path Misbinding y cero estado secreto externo.

2. Modelo de Amenazas y Verificación de Seguridad

El alcance incluyó:

1. Carreras Replay y Sequence
2. Alteración de solicitudes y respuestas
3. Ataques Cross-session y Cross-path
4. Entradas Malformed y Oversized
5. Formas de HTTP Smuggling
6. Fuzz, Soak y Load
7. TOCTOU, FD e Inode Identity
8. Ataques Symlink, Junction y Reparse
9. Loaded-object Identity
10. Inyección de Provider, Dependency y Config
11. Worker Collision y Concurrent Init
12. Ciclo Crash, Restart y Shutdown
13. Reutilización de Stale Session, Lease y Status

2.1 Carreras Replay y Sequence: Observaciones Finales

Plataforma	Solicitudes duplicadas	Aceptaciones por Sequence	Double Handler Execution
Windows Server 2022	1,280	Exactamente una	0
Ubuntu 24.04 LTS	2,880	Exactamente una	0

La prueba no se limitó a observar respuestas de error. Instrumentó por separado si la llegada concurrente del mismo Sequence ejecutaba dos veces el Handler de aplicación.

2.2 Native Loaded-object Identity: Observaciones Finales

En Windows se observaron 3,000 cargas reales de Provider/WinDLL, 1,062 reemplazos atómicos exitosos y 3,000 operaciones de creación/eliminación de Junction. Untrusted DLL Load, Untrusted Dependency Load, Reparse Bypass y Verified-vs-loaded Identity Mismatch fueron cero.

En Ubuntu se verificaron Atomic File, Parent y Symlink Swap; Unsafe Parent; inyección de Dependency, Provider, Module, Engine y Config; FD/Inode Identity; y 50+50 ciclos de vida.

3. Verificación por Plataforma

3.1 Windows Server 2022

- Windows Server 2022 AMD64
- CPython 3.12.10
- Instalación offline bloqueada por hash
- [init](#), protección de segunda inicialización, [doctor](#), [verify](#) y [status](#)
- ML-KEM-768, ML-DSA-65 y Hybrid Handshake reales
- Request Semantic Binding y Response Metadata Boundary
- ACL Trust, Status Authentication y Shutdown Resource Lifetime
- Forced Termination y Second-crash Recovery

3.2 Ubuntu 24.04 LTS

- Ubuntu 24.04.4 LTS AMD64
- CPython 3.12.3
- Instalación offline bloqueada por hash
- [init](#), segunda inicialización, [doctor](#), Negative Doctor, [verify](#) y [status](#)
- ML-KEM-768, ML-DSA-65 y Hybrid Handshake reales
- Admission Fuzz y entrada Malformed u Oversized
- HTTP Smuggling Shape y WebSocket Fail-Closed
- Native Trust, Symlink y Parent Swap, FD/Inode Identity
- Graceful Shutdown, Restart, SIGKILL y Crash Recovery

4. Artefactos y Evidencia

4.1 Wheel Sellado

- Archivo: [odre_pqc-0.2.9-py3-none-any.whl](#)
- SHA-256: [A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697](#)
- RECORD: 45/45 entradas con hash verificadas
- Versiones Package y Runtime: 0.2.9 coincidentes

- SHA-256 idéntico al inicio y al final de la auditoría

4.2 Archivos de Native Runtime

- SHA-256 de Windows Runtime: [826303E72A76B10041D26113F465ADD8960825C71F50722D6792174E73F9D12C](#)
- SHA-256 de Ubuntu Runtime: [EFAD16698203371D07F25B429F6731B9C0954EEBF5B58A0024789EF0611A78D1](#)

4.3 Correspondencia de Informes

Área del libro blanco	Informes principales
v0.1.1	ODRE PQC v0.1.1 - Independent Audit Evidence Log
v0.1.2-v0.1.4	Informes de Version y Clean-room Reverification
v0.2.0	v0.2.0_FINAL_REPORT.md
v0.2.1	v0.2.1_CUSTOMER_ZERO_CONFIG_BOOTSTRAP_REPORT.md , v0.2.1_FINAL_AUDIT_REPORT.md
v0.2.5	v0.2.5_FINAL_REPORT.md , v0.2.5_REMEDIATION_HISTORY.md
v0.2.6	Informes Blind Static, Targeted Repro, Root Cause, Remediation y Multi-review
v0.2.7	Informes Independent Audit y Remediation
v0.2.8	Informes F-027-01, RC03, F-028-01 y Final Release Audit
v0.2.9	F-028-01 Targeted Remediation y Full Development Security Audit

4.4 Separación Entre Problemas del Harness y Defectos del Producto

Seis problemas del Harness identificados en la auditoría final se conservaron separados de los defectos del producto. Tras corregir Fixture y Binding, se repitieron los Gates relevantes sin cambiar los bytes del producto. Los errores del Harness no se interpretaron automáticamente como éxito o fallo del producto; se conservaron las evidencias corregidas y repetidas.

5. Conclusión

La mejora de seguridad de ODRE PQC no fue un único evento de aprobación, sino un proceso iterativo que conservó las pruebas fallidas y conectó sus causas con cambios estructurales posteriores. v0.1.1 bloqueó el bypass en texto plano; la prueba Clean-room de v0.1.2 expuso Sequence Gap y defectos en el orden previo al Handler; v0.1.3 los cerró con Strict Sequence y Pre-handler Contract Enforcement; v0.1.4 añadió observabilidad y reconfirmó el contrato anterior.

Las versiones posteriores ampliaron la verificación desde el límite de integración Python al Native Runtime y la confianza en objetos del sistema operativo. La omisión de ABI en Ubuntu, TOCTOU entre verificación y carga, FD/Inode Identity, Symlink/Junction/Reparse, inyección de Provider/Dependency/Config y el ciclo Crash/Restart/Shutdown se trataron como condiciones de ataque independientes. El Wheel v0.2.9 sellado fue reverificado en Windows Server 2022 y Ubuntu 24.04 LTS conservando el mismo SHA-256.

El artefacto final es [odre_pqc-0.2.9-py3-none-any.whl](#), SHA-256

[A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697](#). Las evidencias vinculan a ese artefacto RECORD 45/45, identidad de inicio/fin de auditoría, runtime real OpenSSL 3.5.8, ML-KEM-768, ML-DSA-65, Hybrid Handshake, carreras Replay, Native Loaded-object Identity y pruebas de ciclo de vida.